WEB APPLICATION VULNERABILITY ASSESSMENT REPORT

Target Website:
futureinterns.com

Assessment Date: April 12, 2026
Classification: Confidential
Scope: Read-Only Passive Analysis
Methodology: OWASP Top 10 / Passive Recon

Security Grade	Total Findings	High Risk	Medium Risk
D	8	1	3

1. Executive Summary

This report presents the findings of a passive, read-only security assessment conducted on futureinterns.com on April 12, 2026. The assessment was performed using ethical, non-intrusive techniques including HTTP header analysis, port reconnaissance, and publicly available scanning tools.

The website received a security grade of D from SecurityHeaders.com, indicating significant gaps in fundamental HTTP security controls. A total of 8 vulnerabilities were identified — 1 rated High, 3 rated Medium, and 4 rated Low severity.

The most critical issue is the absence of an HTTP Strict-Transport-Security (HSTS) header, which can allow attackers to intercept communications even over HTTPS connections. Additionally, the server exposes its technology stack (PHP version, server platform, and hosting panel), reducing the effort required for a targeted attack.

Key Recommendations

- Immediately configure HSTS to enforce HTTPS across all connections.
- Remove X-Powered-By, Server, Platform, and Panel disclosure headers.
- Add X-Frame-Options to prevent clickjacking attacks.
- Implement X-Content-Type-Options to prevent MIME-type sniffing.
- Strengthen the Content-Security-Policy beyond upgrade-insecure-requests.
- Add Referrer-Policy and Permissions-Policy for full header compliance.

2. Scope & Methodology

2.1 Scope of Testing

Testing was limited strictly to passive, read-only analysis of publicly accessible HTTP response headers and infrastructure. No authentication bypass, exploitation, brute-forcing, or any active attack techniques were used.

2.2 Tools Used

- curl — HTTP header extraction and response analysis
- nmap — Network port and service enumeration
- SecurityHeaders.com — Automated security header grading
- Browser DevTools — Cookie and client-side inspection

2.3 Ethical Guidelines

This assessment follows strict ethical guidelines. All analysis was performed passively on publicly accessible endpoints only. No data was extracted, modified, or damaged during testing.

3. Findings Summary

ID	Vulnerability	Location	Risk
F-01	X-Powered-By Header Disclosure	HTTP Response Headers	Low
F-02	Server & Platform Info Disclosure	HTTP Response Headers	Low
F-03	Missing Strict-Transport-Security	HTTP Response Headers	High
F-04	Missing X-Frame-Options	HTTP Response Headers	Medium
F-05	Missing X-Content-Type-Options	HTTP Response Headers	Medium
F-06	Missing Referrer-Policy	HTTP Response Headers	Low
F-07	Missing Permissions-Policy	HTTP Response Headers	Low
F-08	Weak Content-Security-Policy	HTTP Response Headers	Medium

4. Detailed Findings

F-01 X-Powered-By Header Disclosure

Risk Level
Low

Location
HTTP Response Header: x-powered-by

Description
The server returns 'x-powered-by: PHP/8.2.30' in every HTTP response. This reveals the exact PHP version running on the server to any visitor or attacker.

Business Impact
An attacker who knows the exact PHP version can look up known CVEs (security vulnerabilities) specific to that version and target the server more precisely. This reduces the effort required to plan an attack.

Recommended Fix
Add the following to your server config: 'php_flag expose_php Off' (PHP) or remove the header via your web server/LiteSpeed configuration panel.

Evidence
Observed via: curl -I https://futureinterns.com — Screenshot 1 (Image 1 in evidence)

F-02 Server & Platform Information Disclosure

Risk Level
Low

Location
HTTP Response Headers: server, platform, panel

Description
The server responses expose three separate infrastructure headers: 'server: LiteSpeed', 'platform: hostinger', and 'panel: hpanel'. Together, these reveal the full hosting stack.

Business Impact
This gives an attacker a complete picture of the hosting environment — the web server software, hosting provider, and control panel. Targeted exploits exist for each of these platforms. Attackers may also attempt to contact the hosting provider using social engineering.

Recommended Fix
Suppress these headers in LiteSpeed's configuration. Under cPanel/hPanel, look for 'Server Signature' or 'Header Security' settings and disable them. Contact Hostinger support if needed.

Evidence
Observed via: curl -I https://futureinterns.com — Screenshot 1 (Image 1 in evidence)

F-03 Missing HTTP Strict-Transport-Security (HSTS) Header

Risk Level
High

Location
HTTP Response Headers

Description
The Strict-Transport-Security header is absent from server responses. HSTS tells browsers to always use HTTPS and never downgrade to HTTP, even if a user types the URL without https://.

Business Impact
Without HSTS, a man-in-the-middle attacker on the same network (e.g., a coffee shop Wi-Fi) can intercept traffic by forcing the browser to connect over insecure HTTP. This can expose user data, session tokens, and login credentials.

Recommended Fix

Add this to your web server config: Strict-Transport-Security: max-age=31536000; includeSubDomains; preload — This enforces HTTPS for one full year, including all subdomains.

Evidence

Confirmed missing via SecurityHeaders.com scan — Screenshot 3 (Image 3 in evidence)

F-04 Missing X-Frame-Options Header

Risk Level
Medium

Location
HTTP Response Headers

Description

The X-Frame-Options header is not set. This means the website can be embedded inside an iframe on any external website without restriction.

Business Impact

This opens the door to clickjacking attacks, where an attacker overlays an invisible copy of your website on top of their own page. Users think they are clicking harmless buttons on the attacker's page but are actually clicking elements on your site — potentially triggering unintended actions like purchases or form submissions.

Recommended Fix

Add to your server config: X-Frame-Options: SAMEORIGIN (allows framing only by the same domain) or X-Frame-Options: DENY (blocks all framing).

Evidence

Confirmed missing via SecurityHeaders.com scan — Screenshot 3 (Image 3 in evidence)

F-05 Missing X-Content-Type-Options Header

Risk Level
Medium

Location
HTTP Response Headers

Description

The X-Content-Type-Options: nosniff header is absent. Without it, browsers may attempt to 'sniff' (guess) the content type of a response, ignoring the declared Content-Type header.

Business Impact

An attacker can upload a file that appears benign (e.g., a text file) but is actually a script. Without this header, some browsers may execute it as a script, enabling cross-site scripting (XSS) attacks or drive-by malware downloads.

Recommended Fix

Add to your server config: X-Content-Type-Options: nosniff — This is a one-line fix with no side effects on legitimate traffic.

Evidence

Confirmed missing via SecurityHeaders.com scan — Screenshot 3 (Image 3 in evidence)

F-06 Missing Referrer-Policy Header

Risk Level
Low

Location

Description

No Referrer-Policy header is set. By default, browsers send the full URL of the page a user came from (the 'referrer') to external sites when clicking links.

Business Impact

HTTP Response Headers	If a user visits a private or internal page and then clicks a link to an external site, that external site receives the full URL of the private page. This can leak sensitive URL parameters, user IDs, or session-related information to third parties. **Recommended Fix** Add: Referrer-Policy: strict-origin-when-cross-origin — This sends referrer info only within the same site and only the domain (not full URL) when going cross-origin. **Evidence** *Confirmed missing via SecurityHeaders.com scan — Screenshot 4 (Image 4 in evidence)*

F-07 Missing Permissions-Policy Header

Risk Level **Low** **Location** HTTP Response Headers	**Description** The Permissions-Policy header (formerly Feature-Policy) is absent. This header controls which browser features and APIs the website is allowed to use. **Business Impact** Without this header, any malicious script injected into the page (via XSS or third-party scripts) could access sensitive browser features like the camera, microphone, geolocation, or payment APIs without restriction. **Recommended Fix** Add: Permissions-Policy: camera=(), microphone=(), geolocation=(), payment=() — This disables these features by default unless explicitly needed. **Evidence** *Confirmed missing via SecurityHeaders.com scan — Screenshot 5 (Image 5 in evidence)*

F-08 Weak Content-Security-Policy (CSP)

Risk Level **Medium** **Location** HTTP Response Header: content-security-policy	**Description** A Content-Security-Policy header is present, but its value is only 'upgrade-insecure-requests'. This is the bare minimum — it only upgrades HTTP requests to HTTPS but does nothing to prevent cross-site scripting or unauthorised resource loading. **Business Impact** A weak CSP provides a false sense of security. Cross-site scripting (XSS) attacks, malicious inline script injection, and loading of unauthorised external resources remain fully unmitigated. **Recommended Fix** Strengthen the CSP policy to whitelist approved sources. A starting example: Content-Security-Policy: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data: https:; Use report-uri to monitor violations before enforcing. **Evidence** *Observed via: curl -I response and SecurityHeaders.com scan — Screenshots 1-2 in evidence*

5. Remediation Roadmap

Prioritise fixes in this order. All header-based fixes can typically be implemented within 1-2 hours by a developer or system administrator.

Priority	Action	Effort	Risk Resolved
1 — URGENT	Add Strict-Transport-Security header	< 30 min	High
2	Remove X-Powered-By, server, platform, panel headers	< 1 hour	Low x2
3	Add X-Frame-Options: SAMEORIGIN	< 15 min	Medium
4	Add X-Content-Type-Options: nosniff	< 15 min	Medium
5	Strengthen Content-Security-Policy	2-4 hours	Medium
6	Add Referrer-Policy header	< 15 min	Low
7	Add Permissions-Policy header	< 15 min	Low

6. Conclusion

The security assessment of futureinterns.com identified 8 vulnerabilities, none of which require a significant engineering effort to remediate. All findings relate to missing or misconfigured HTTP response headers — a common and easily fixable class of issues.

Implementing the recommended headers will immediately improve the site's security posture from a D grade to an A or A+, significantly reducing the risk of clickjacking, man-in-the-middle attacks, MIME-type confusion attacks, and information disclosure.

It is recommended to re-test the website after implementing these fixes and to establish a recurring security review process — at minimum, every 6 months or after any significant infrastructure change.

Disclaimer: This report was produced for educational purposes as part of a security consulting learning exercise. All testing was passive and read-only. No systems were harmed, modified, or exploited. The findings reflect the state of the target at the time of assessment.